

Cyber Security Task 3

API Security Risk Analysis

Target: <https://reqres.in>

Tested by: Kashish Maurya

Tool Used: Postman

Table of Contents

1. Introduction
2. Scope of Testing
3. Testing Methodology
4. Summary of Findings
5. Detailed Vulnerability Findings
6. Conclusion & Recommendations

1. Introduction

This report presents the findings of an API security assessment conducted using Postman to test for potential information disclosure vulnerabilities and identify authentication flaws.

2. Scope of Testing

In Scope:

POST https://reqres.in/api/login

GET https://reqres.in/api/users

Out of Scope: Any endpoints or functionality not explicitly listed above. No destructive testing, denial-of-service testing, credential attacks, or unauthorized access attempts were performed.

3. Testing Methodology

The API security assessment was conducted using Postman through non-destructive testing.

1. Identified the API endpoints within the defined testing scope.
2. Sent requests to the selected endpoints using Postman.
3. Tested the login endpoint with credential variations and reviewed the resulting HTTP response.
4. Tested the users endpoint without authentication and reviewed the returned data.
5. Examined response status codes and response bodies for security-relevant observations.
6. Documented the identified risks and assessed their potential security impact.

4. Summary Table

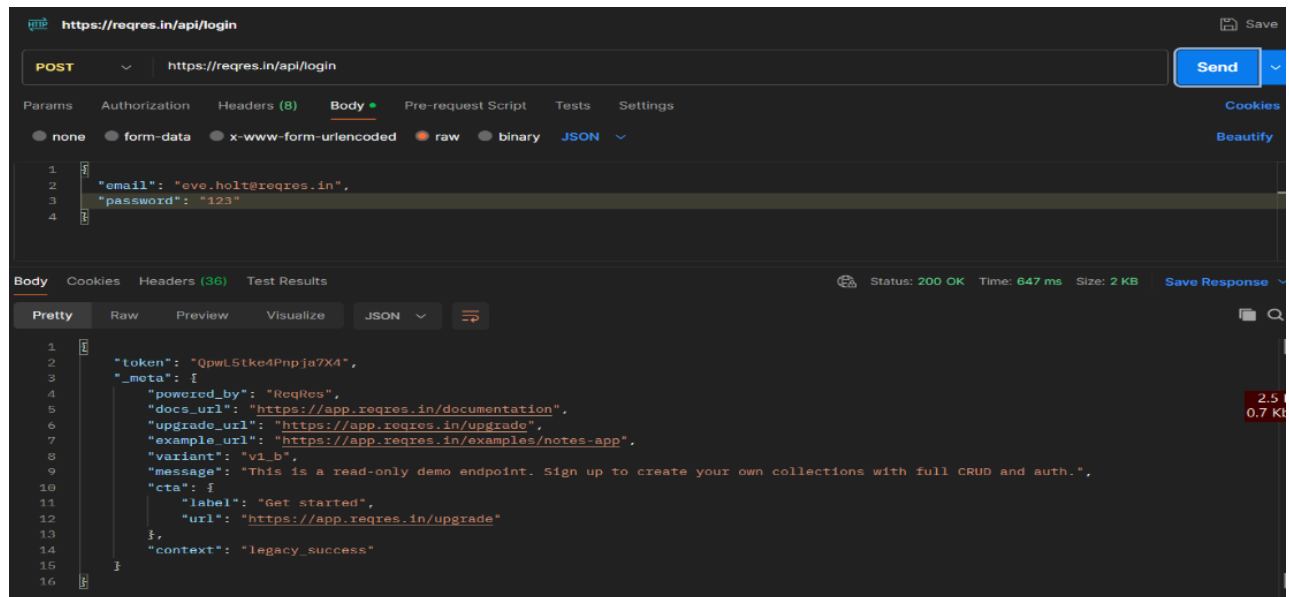
Finding	Severity	Evidence	Impact	Remediation
Authentication issue	High*	Postman response	Potential unauthorized access*	Correct credential validation
Information disclosure	Medium*	/api/users response	Exposure of user information	Authentication + data minimization

5. Finding Details

Finding 1: Broken Authentication (HIGH)

During testing of the /api/login endpoint, the API returned a successful HTTP response and a token-like value under the tested invalid-credential condition. This behavior may indicate insufficient credential validation; however, token issuance alone does not conclusively demonstrate an authentication bypass. Further testing would be required to determine whether the returned token provides access to protected resources.

PROOF:



Request: POST /api/login

Authentication: None

Test condition: Invalid credentials

Observed HTTP status: 200 OK

Observed response: Token returned

Business Impact

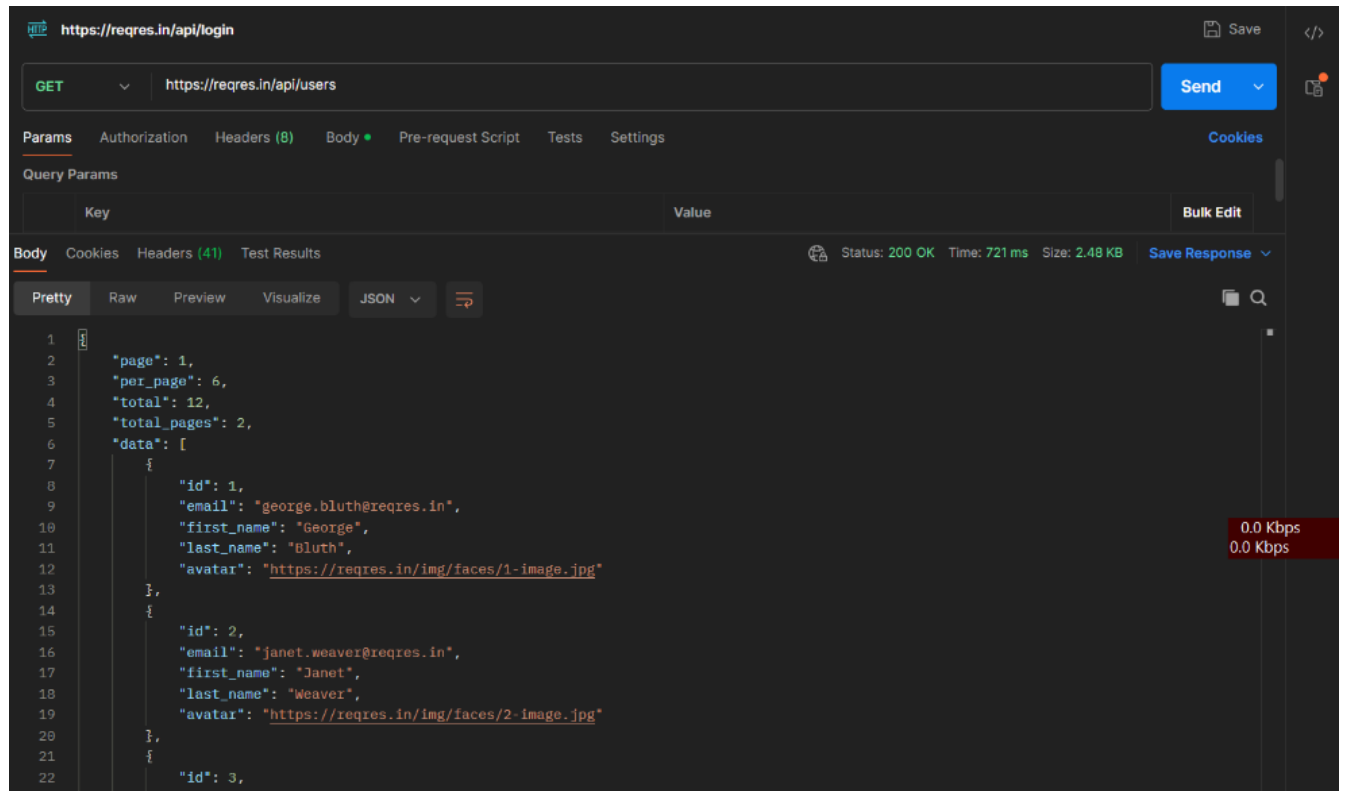
If an authentication mechanism accepts invalid credentials and issues a usable authentication token, unauthorized users may potentially gain access to protected resources. This could lead to unauthorized account access, exposure of sensitive information, or unauthorized actions depending on the privileges associated with the token.

Finding 2: Information Disclosure (MEDIUM)

The /api/users endpoint returned user records, including email addresses, without requiring authentication. In a production application, exposing non-public personal information through an

unauthenticated endpoint could constitute an information-disclosure vulnerability. However, because ReqRes is a publicly available API testing service and the endpoint is intended to demonstrate API functionality, this observation should be treated as a security testing observation rather than automatically classified as a confirmed vulnerability.

PROOF:



Request: GET /api/users

Authentication: None

Observed HTTP status: 200 OK

Observed response: User records containing email addresses

Business Impact

Unauthenticated exposure of user information can increase privacy risk and provide attackers with information that may be useful for profiling, enumeration, or targeted attacks.

6. Conclusion and Recommendations

The API security assessment identified two security risks: Broken Authentication and Information Disclosure. The findings highlight the need for proper authentication, authorization, and protection of user information.

Finding 1 — Recommended Remediation

- Validate the supplied credentials against the authentication service before issuing a token.
- Never issue an authentication token when authentication fails.
- Return an appropriate authentication error for invalid credentials.
- Ensure tokens are issued only after successful authentication.
- Test authentication behavior with valid and invalid credentials.

Finding 2 — Recommended Remediation

- Require authentication and authorization for endpoints containing non-public user information.
- Return only the minimum information required by the client.
- Apply proper access controls to user records.
- Review API responses for unnecessary exposure of email addresses and other personal information.